

VULNERABILITY ASSESSMENT REPORT

TARGET WEBSITE

<https://demo.testfire.net>

INTERNSHIP PROGRAM

Future Interns – Cyber Security Internship

TASK

Cyber Security Task 1 (2026)

ASSESSMENT TYPE

Read-Only Vulnerability Assessment

DATE

June 2026



Prepared by

Animireddy Tejaswani

Executive Summary

- This report presents the results of a read-only vulnerability assessment conducted on the public website <https://demo.testfire.net>.
- The assessment was performed using passive security testing techniques to identify common security weaknesses without exploiting or disrupting the target system.
- A total of 15 findings were identified during the assessment, primarily involving missing security headers, inadequate security controls, and information disclosure issues.
- This report focuses on the most significant findings and provides recommendations to strengthen the application's security posture.

Scope and Methodology

ASSESSMENT SCOPE

TARGET WEBSITE:

<https://demo.testfire.net>

ASSESSMENT TYPE:

Read-Only Vulnerability Assessment

TESTING APPROACH:

Passive Security Testing

METHODOLOGY

- Service Enumeration
- Security Header Analysis
- Configuration Review
- Passive Vulnerability Identification
- Evidence Collection

TOOLS USED

- Nmap
- OWASP ZAP
- Browser Developer Tools



kali@kali: ~

Session Actions Edit View Help

~(kali@kali)-[~]

\$ nmap -sV demo.testfire.net

Starting Nmap 7.99 (<https://nmap.org>) at 2026-06-09 09:59 -0400

Nmap scan report for demo.testfire.net (65.61.137.117)

Host is up (0.030s latency).

Not shown: 996 filtered tcp ports (no-response)

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

80/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
--------	------	------	-------------------------------------

443/tcp	open	ssl/http	Apache Tomcat/Coyote JSP engine 1.1
---------	------	----------	-------------------------------------

8080/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
----------	------	------	-------------------------------------

8443/tcp closed https-alt

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 53.21 seconds

~(kali@kali)-[~]

\$



Music



Videos



Downloads



Devices



File System



sf_Kali



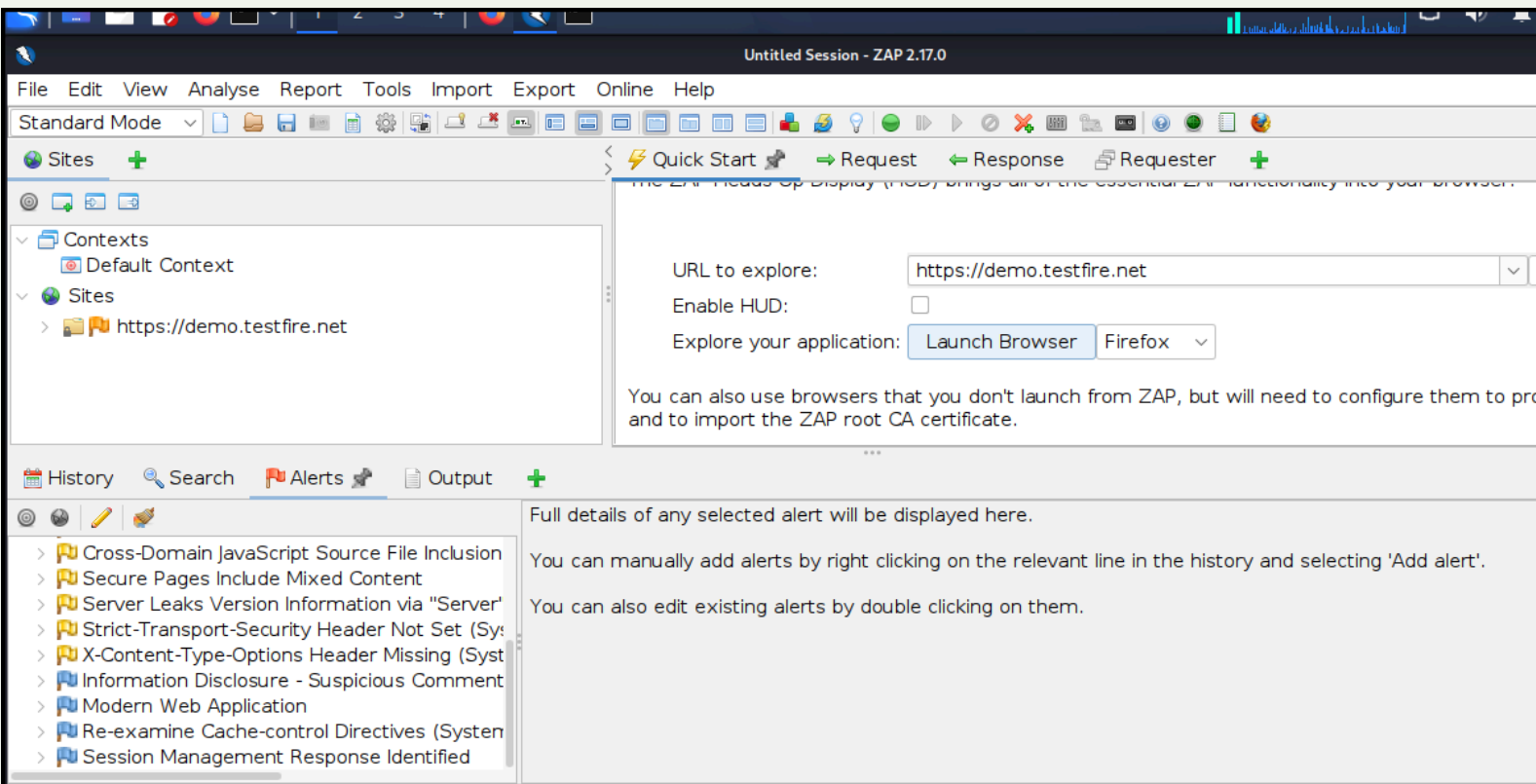
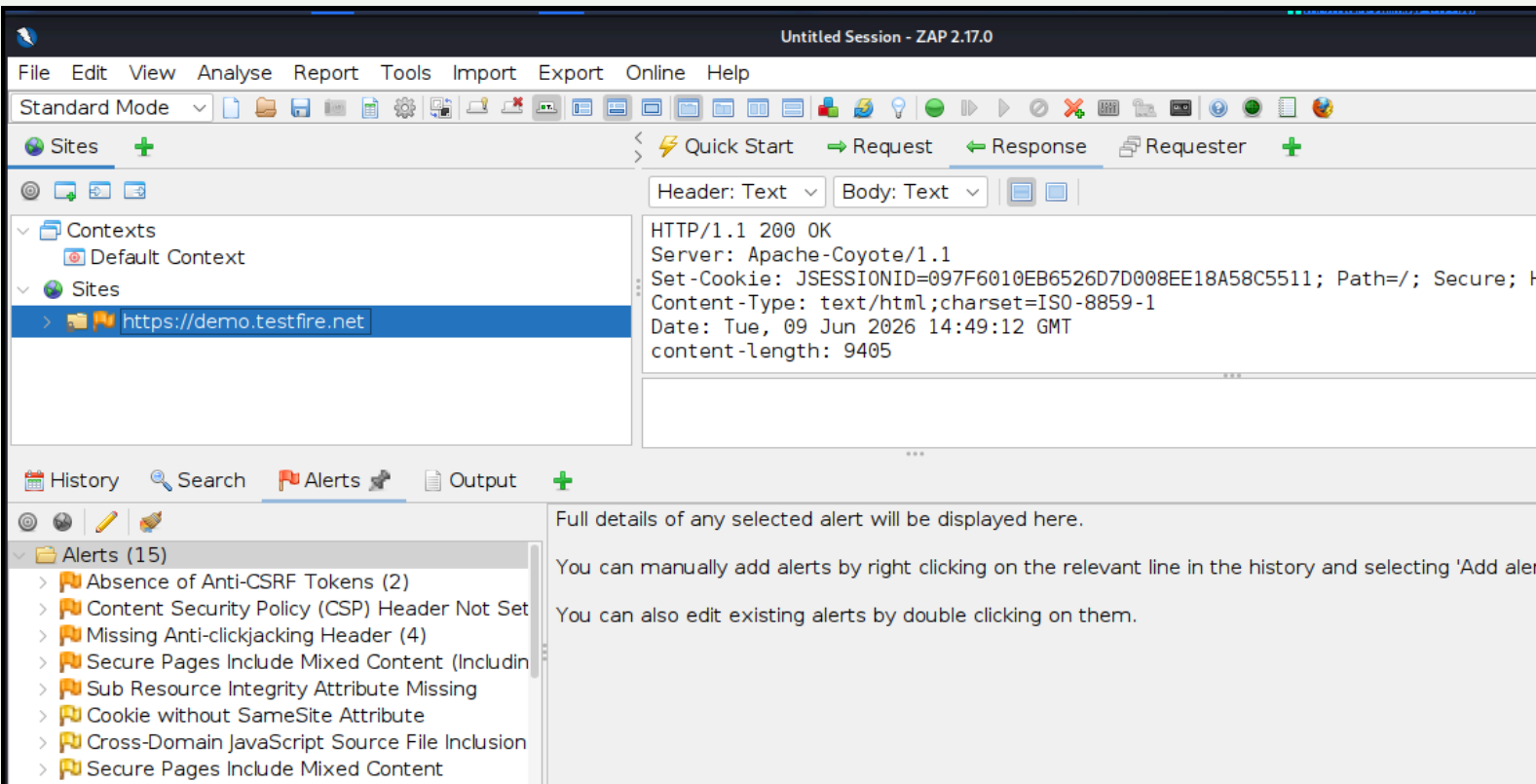
Network



Browse Network

Findings Summary

A total of 15 security-related findings were identified during the passive assessment.



Risk Distribution

Medium Risk Findings : 5

Low Risk Findings : 7

Informational Findings : 4

Detailed Findings Covered in this Report

- Absence of Anti-CSRF Tokens
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header

Additional findings are summarized in the
Appendix section.

Finding 1 : Absence of Anti-CSRF Tokens

Risk Level : Medium

Description

The application does not implement Anti-CSRF protection mechanisms for certain forms. This may allow attackers to trick authenticated users into performing unintended actions.

Impact

An attacker could exploit this weakness to submit unauthorized requests on behalf of legitimate users.

Recommendation

Implement Anti-CSRF tokens for all sensitive forms and validate them on the server side.

Absence of Anti-CSRF Tokens

URL:	https://demo.testfire.net/login.jsp
Risk:	Medium
Confidence:	Low
Parameter:	
Attack:	
Evidence:	1" onSubmit="return (confirminput(login));">
CWE ID:	352
WASC ID:	9

Description:

No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target

Other Info:

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf token, csrf, csrfSecret, csrf magic, CSRF.

Solution:

Phase: Architecture and Design
Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.

Reference:

https://cheatsheetseries.owasp.org/cheatsheets/Cross-

HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Content-Type: text/html; charset=ISO-8859-1
Date: Tue, 09 Jun 2026 14:49:55 GMT
content-length: 8555

</p>

<form action="doLogin" method="p

ce of Anti-CSRF Tokens

https://demo.testfire.net/login.jsp

Medium

ence: Low

eter:

ce: <form action="doLogin" method="post" name=

o: 352

ID: 9

Finding 2 : Content Security Policy Header Not Set

Risk Level : Medium

Description

The application does not define a Content Security Policy (CSP), reducing protection against client-side attacks such as Cross-Site Scripting (XSS).

Impact

Attackers may inject malicious scripts that could compromise user sessions or steal sensitive information.

Recommendation

Configure a restrictive Content Security Policy header to control the sources from which content can be loaded.

Finding 3 : Missing Anti-clickjacking Header

Risk Level : Medium

Description

The application does not include clickjacking protection headers, allowing pages to be embedded within malicious websites.

Impact

Users may unknowingly interact with hidden elements placed over legitimate web pages.

Recommendation

Implement the X-Frame-Options header or use the frame-ancestors directive within the Content Security Policy.

Missing Anti-clickjacking Header

URL:

https://demo.testfire.net/

Risk:

Medium

Confidence:

Medium

Parameter:

x-frame-options

Attack:

Evidence:

CWE ID:

1021

WASC ID:

15

Description:

The response does not protect against 'Clickjacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Other Info:

Solution:

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

Reference:

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Online Help

Quick Start

Request

Response

Header: Text

Body: Text

HTTP/1.1 200 OK

Server: Apache-Coyote/1.1

Set-Cookie: JSESSIONID=097F6010EB6526D7

Content-Type: text/html; charset=ISO-885

Date: Tue, 09 Jun 2026 14:49:12 GMT

content-length: 9405

g Anti-clickjacking Header

https://demo.testfire.net/

Medium

Medium

x-frame-options

1021

15

Additional Findings

The following observations were identified during the assessment but were not analyzed in detail.

Finding	Risk Level
Cookie without SameSite Attribute	Medium
Server Version Disclosure	Low
X-Content-Type-Options Header Missing	Low
Information Disclosure - Suspicious Comments	Informational
Cross-Domain JavaScript Source File Inclusion	Informational
Sub Resource Integrity Attribute Missing	Informational
Other Passive Scan Findings	Informational

Conclusion

The assessment identified several security configuration weaknesses within the target application.

No active exploitation or intrusive testing was performed during this engagement. The identified findings primarily involve missing security headers and inadequate protection mechanisms.

Implementing the recommended controls will significantly improve the application's resilience against common web-based attacks and strengthen its overall security posture.

Assessment Summary

Total Findings : 15

Detailed Findings : 3

Assessment Method : Passive Security
Testing

Testing Status : Completed